

시큐어코딩



SW개발보안 방법론

01 소프트웨어 개발보안 방법론
02 MS-SDL



학습 목표

- ✓ 소프트웨어 개발보안 방법론의 개념과 필요성을 이해한다.
- ✓ SW개발 생명주기(SDLC) 전 단계에 걸친 보안 활동의 목적과 내용을 이해한다.
- ✓ MS-SDL의 단계별 보안 적용 사례를 이해하고 설명할 수 있다.
- ✓ 보안을 고려한 소프트웨어 개발이 왜 중요한지, 기업 및 조직에 미치는 영향을 인식한다.

학습 내용

1. 소프트웨어 개발보안 방법론의 주요 개념과 원칙
2. SDLC 단계별 보안활동(분석, 설계, 구현, 테스트)의 핵심 내용
3. 보안 적용 시 비용 절감 효과
4. MS-SDL 단계별 보안 적용 사례



SW개발보안 방법론

01 소프트웨어 개발보안 방법론

02 MS-SDL

SW개발보안 방법론

SW 개발 보안 방법론은 소프트웨어 개발 과정에서 보안성을 강화하기 위해 적용하는 체계적인 접근 방식. 소프트웨어 개발 생명주기(SDLC: Software Development Life Cycle) 전반에 걸쳐 보안 요구사항을 반영하고, 취약점을 예방하는 것을 목표로 함.

SW 개발 보안 방법론의 주요 개념

보안 내재화(Security by Design): 개발 초기부터 보안을 고려하여 설계

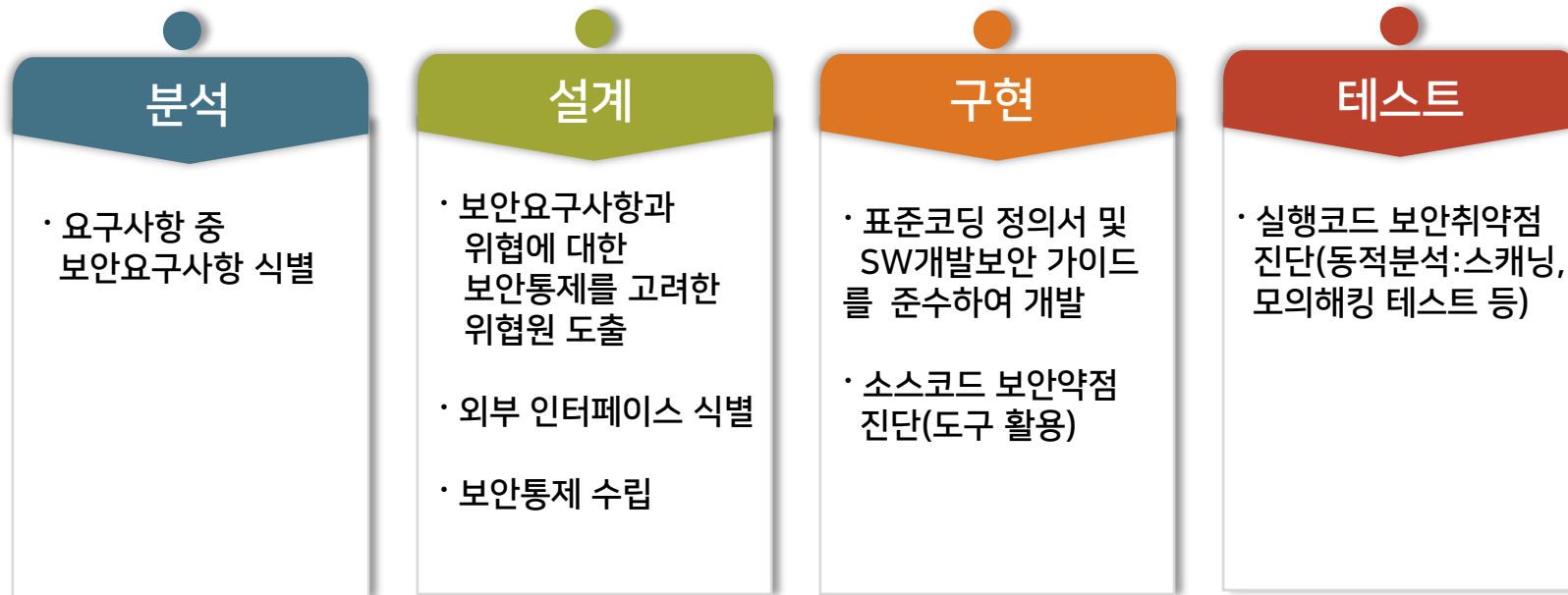
취약점 최소화(Minimization of Vulnerabilities): 코드 및 시스템의 보안 결함을 줄이는 방식 적용

지속적인 보안 점검(Continuous Security Assessment): 주기적인 테스트 및 검증 수행

SW개발보안 방법론

SW 개발보안이란?

안전한 SW 개발을 위해 소스코드 등에 존재할 수 있는 잠재적인 보안 약점을 제거하고,
보안을 고려하여 기능을 설계 ▪ 구현하는 등 SW 개발 과정에서 실행되는 일련의 보안활동



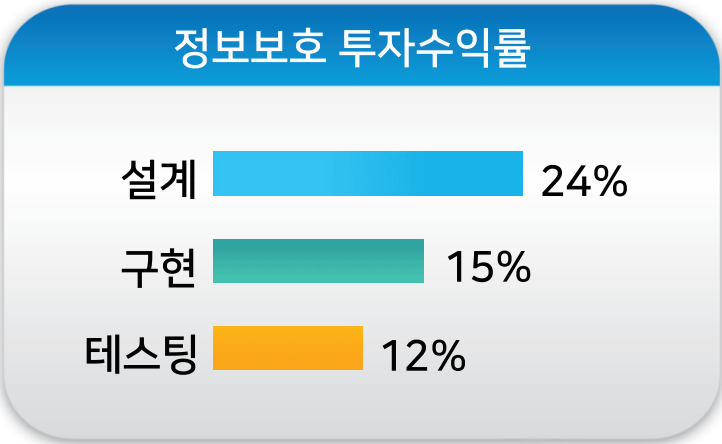
- ※ 현재는 SW 개발과정 중 소스코드 구현단계를 중심으로 SW 개발보안 적용
- ※ 보안취약점(Vulnerability) : 해킹 등 실제 보안사고에 이용되는 SW 보안약점
- ※ 보안약점 (Weakness) : 보안취약점의 근본 원인이 되는 SW 상의 허점, 결점, 오류 등

SW개발보안 적용 시 비용 효과

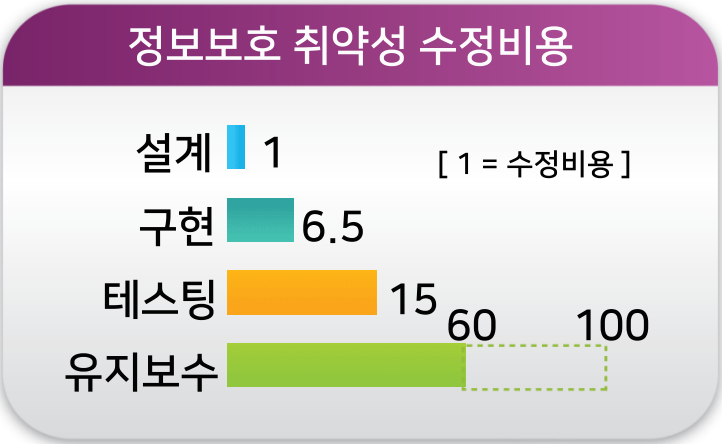
<SW 개발 단계별 결함 수정비용 분석>

구분	설계단계	코딩단계	통합단계	베타제품	제품출시
설계과정 결함	1배	5배	10배	15배	30배
코딩과정 결함		1배	10배	20배	30배
통합과정 결함			1배	10배	20배

※ 출처 : The Economic Impacts of Inadequate Infrastructure for SW Testing(2002.5, NIST)



※ 출처 : IBM 연구보고서



※ 출처 : 마이크로소프트

SW개발보안 방법론 적용의 중요성

- 해킹, 데이터 유출 등 보안 사고 예방
- 법적 규제(개인정보 보호법, GDPR, ISO 27001 등) 준수
- 개발 비용 절감 (초기 단계에서 보안 문제 해결 시 비용 절감 효과)
- 신뢰할 수 있는 소프트웨어 제공으로 기업 이미지 및 서비스 경쟁력 강화



SW개발보안 방법론

01 소프트웨어 개발보안 방법론

02 MS-SDL

소프트웨어 개발보안 적용 우수사례 MS-SDL

1. MS-SDL이란?

MS-SDL(Microsoft Security Development Lifecycle)은 마이크로소프트(Microsoft)에서 개발한 소프트웨어 보안 개발 방법론으로, 소프트웨어 개발 생명주기(SDLC) 전반에 걸쳐 보안을 내재화하는 것을 목표로 함
보안 취약점을 최소화하고, 보안 사고를 예방하며, 강력한 보안 정책을 소프트웨어 개발 과정에 적용하는 방법론

2. MS-SDL의 주요 목표

1. 보안 취약점 예방: 개발 초기부터 보안 요구사항을 반영하여 보안 문제를 사전에 차단
2. 위험 감소: 보안 테스트 및 코드 검토를 통해 공격에 대한 노출을 최소화
3. 법규 및 규제 준수: 개인정보 보호, 보안 표준(ISO/IEC 27001, GDPR 등) 준수
4. 비용 절감: 개발 후반이 아닌 초기에 보안 문제를 해결하여 유지보수 비용 절감

소프트웨어 개발보안 적용 우수사례 MS-SDL

보안 개발 방법론의 대표적인 사례로 마이크로소프트(Microsoft)의 개발 생명주기(MS-SDL)는 자체적으로 개발한 개발 생명주기를 제품 개발 전 과정에 적용하여 보안취약점의 원인을 제거하도록 하였다.



교육 및 보안인식 단계

- 소프트웨어 개발팀의 구성원들을 대상으로 매년 한 번씩 보안의 기초와 최신 보안 동향에 대해 교육
- 보안 교육은 안전설계, 위협모델링, 시큐어코딩, 보안테스팅, 프라이버시에 관한 내용 포함

소프트웨어 개발보안 적용 우수사례 MS-SDL

마이크로소프트에서 적용한 MS-SDL



요구사항 정의 단계

- 보안 및 개인정보 보호 요구사항 정의
- 법적/규제 요건(예: GDPR, HIPAA, ISO 27001) 검토
- 위협 모델링 수행 필요성 확인

소프트웨어 개발보안 적용 우수사례 MS-SDL

마이크로소프트에서 적용한 MS-SDL



설계단계

- 위협 모델링(Threat Modeling) 수행
 - . 시스템의 공격 표면(Attack Surface) 분석
 - . 보안 위험 평가 및 설계 개선
- 안전한 소프트웨어 아키텍처 설계
- 데이터 보호 및 암호화 정책 정의

소프트웨어 개발보안 적용 우수사례 MS-SDL

마이크로소프트에서 적용한 MS-SDL



구현 단계

- 안전한 코딩(Security Coding) 원칙 적용
 - . OWASP Secure Coding Guide 준수
 - . 보안 API 활용 (예: 인증, 접근 제어, 암호화)
- 정적 분석(SAST) 수행
 - . 코드 내 취약점 자동 탐지 (예: SQL Injection, XSS)
- 취약점 라이브러리 및 구성 요소 제거
 - . 최신 보안 패치 적용
 - . 서드파티 라이브러리의 취약점 관리

소프트웨어 개발보안 적용 우수사례 MS-SDL

마이크로소프트에서 적용한 MS-SDL



검증 단계

- 보안 테스트(Security Testing) 수행
 - . 정적 분석(SAST) 및 동적 분석(DAST) 도구 활용
 - . 침투 테스트(Penetration Testing) 수행
- 위험 기반 보안 점검
 - . 중요 기능(인증, 접근 제어, 암호화)의 보안 검증
 - . 코드 리뷰 및 취약점 제거

소프트웨어 개발보안 적용 우수사례 MS-SDL

마이크로소프트에서 적용한 MS-SDL



배포 단계

- 최종 보안 점검(Security Review) 수행
 . 남아있는 보안 이슈 확인 및 해결
- 디지털 서명 및 무결성 검증
 . 배포 패키지의 보안 검증
- 보안 가이드 문서 제공
 . 사용자를 위한 보안 정책 및 설정 안내

소프트웨어 개발보안 적용 우수사례 MS-SDL

마이크로소프트에서 적용한 MS-SDL



운영 및 유지보수 단계

- 보안 모니터링 및 로그 분석 : 이상 징후 탐지 및 대응 체계 구축
- 보안 패치 및 업데이트 관리 : 취약점 발견 시 신속한 대응
- 보안 사고 대응 프로세스 마련 : 침해사고 발생 시 대응 계획 실행



요약 정리

- ✓ SW 개발보안은 개발 전 과정에서 보안을 적용하는 방법론이다.
- ✓ 분석~테스트 단계별로 보안 활동을 수행한다.
- ✓ 조기 보안 적용은 사고 예방과 비용 절감에 효과적이다.
- ✓ MS-SDL은 마이크로소프트의 대표적 보안 개발 방법이다.
- ✓ 교육부터 운영까지 모든 단계에 보안을 반영한다.



참고 문헌

- [KISA] 소프트웨어 개발 보안 가이드(2021.12.29)
- [KISA] 소프트웨어 보안약점 진단가이드(2021)
- [에이콘출판사] 보안 위협 모델링 Threat Modeling - 위협 식별과 대응을 위한 소프트웨어 설계
- [책만] 모두를 위한 소프트웨어 보안 설계와 구현 - 취약점 분석부터 위협 모델링과 완화 전략, 보안 패턴, 암호화까지 안전한 소프트웨어의 모든 것
- MS-SDL - <https://learn.microsoft.com/ko-kr/compliance/assurance/assurance-microsoft-security-development-lifecycle>

The background is a vibrant blue gradient. It is decorated with various abstract elements: a large solid blue sphere in the upper left, a smaller sphere with diagonal stripes in the upper right, and another striped sphere in the lower left. Several network diagrams, consisting of white dots connected by thin white lines, are scattered across the image. There are also solid blue rectangular bars of different sizes and orientations. The overall aesthetic is modern and technological.

감사합니다.



퀴즈

1. 다음 중 SW개발보안 방법론의 주요 개념이 아닌 것은?

- 1) 지속적인 보안 점검
- 2) 보안 내재화
- 3) SBOM 다중화
- 4) 취약점 최소화

2. 다음 중 SW 결함 수정비용이 가장 많이 필요한 경우는?

- 1) 코딩과정 발생한 결함이 통합 단계에서 발견된 경우
- 2) 설계과정 발생한 결함이 제품 출시 단계에서 발견된 경우
- 3) 설계과정 발생한 결함이 코딩 단계에서 발견된 경우
- 4) 통합과정 발생한 결함이 제품출시 단계에서 발견된 경우

3. 다음 중 MS-SDL 보안개발 방법론에 대한 설명 중 틀린 것은?

- 1) 보안 문제를 사전에 차단한다.
- 2) 요구사항 정의 단계에 위협 모델링을 수행한다.
- 3) 구현 단계에서 정적 분석을 수행한다.
- 4) 배포 단계에서 보안 가이드 문서를 제공한다.



퀴즈 정답

1. 다음 중 SW개발보안 방법론의 주요 개념이 아닌 것은?

3) SBOM 다중화

SW개발보안 방법론의 주요 개념은 보안 내재화, 취약점 최소화, 지속적인 보안 점검입니다.

2. 다음 중 SW 결함 수정비용이 가장 많이 필요한 경우는?

2) 설계과정 발생한 결함이 제품 출시 단계에서 발견된 경우

개발의 최초 과정에서 발생한 결함이 최종 출시 단계까지 가서 알게 된다면 가장 많은 수정비용이 발생합니다.

3. 다음 중 MS-SDL 보안개발 방법론에 대한 설명 중 틀린 것은?

2) 요구사항 정의 단계에 위협 모델링을 수행한다.

위협 모델링은 설계 단계에 수행하는 내용에 해당합니다.